

The background is a dark blue-tinted image of an industrial factory floor. In the center, the text 'UnISENAI' is displayed in a large, bold, sans-serif font. The 'Uni' part is light blue, and 'SENAI' is white. Below the main text, the phrase 'O FUTURO COMEÇA POR VOCÊ!' is written in a smaller, white, all-caps sans-serif font. On the right side of the image, there are several semi-transparent circular graphics that look like gauges or data displays. One gauge shows '80%', another shows '79%', and a larger one in the foreground shows '94%'. There are also some faint numbers like '01-1000' visible on the background elements.

UnISENAI

O FUTURO COMEÇA
POR VOCÊ!

Fundamentos de Segurança da Informação

01 - Gerenciamento e princípios da segurança da informação

UniSENAI



01 - Gerenciamento da segurança da informação

1 - GSI Gerenciamento da segurança da informação



É um processo abrangente que visa proteger as informações e os sistemas de informação de uma organização contra ameaças e riscos.

*SGI: Sistema de gerenciamento da segurança da informação

1.1 - Classificação da informação

 **Classificação da informação:** inventariar e classificar as informações de acordo com sua confidencialidade e associá-las a um proprietário da informação;



1.1 - Classificação da informação

 **Nível Confidencial:** É a mais alta das classificações de informações. Os dados precisam ser rigorosamente protegidos. Se vazados, podem trazer grandes prejuízos - tanto financeiros quanto de imagem - à corporação.

Geralmente, esse grupo de classificação é protegido por criptografia.



1.1 - Classificação da informação

 **Restrito:** Podemos dizer que o restrito é o nível médio de confidencialidade. Informações classificadas nesse grupo são importantes e, por isso, o acesso deve ser permitido apenas às pessoas autorizadas.



1.1 - Classificação da informação

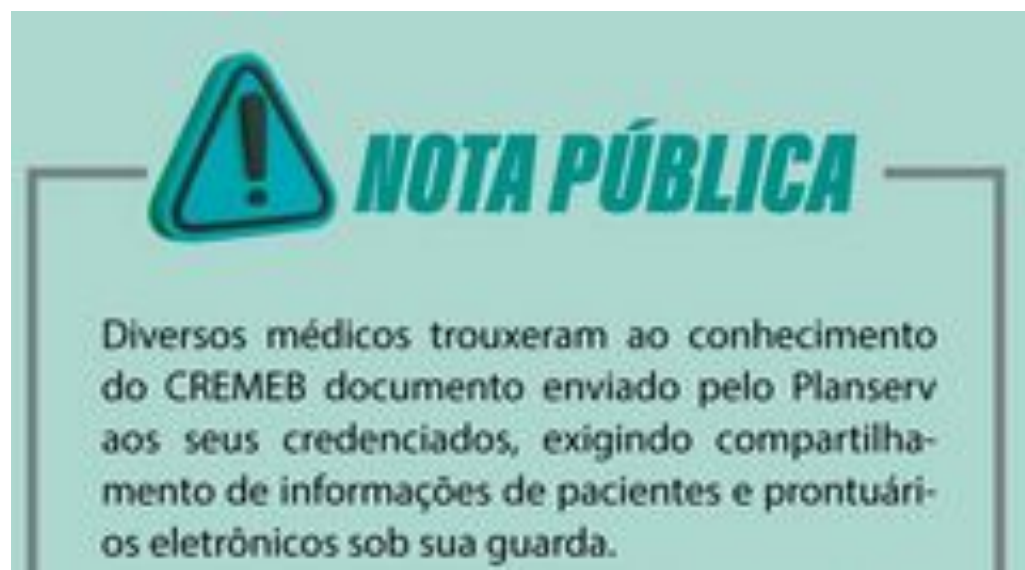
 **Uso Interno:** Possui um baixo nível de *confidencialidade*, sendo sua maior preocupação a completude da informação.

Essas informações não podem ser compartilhadas com pessoas fora da empresa mas, se isso acontecer, a corporação não terá grandes problemas.

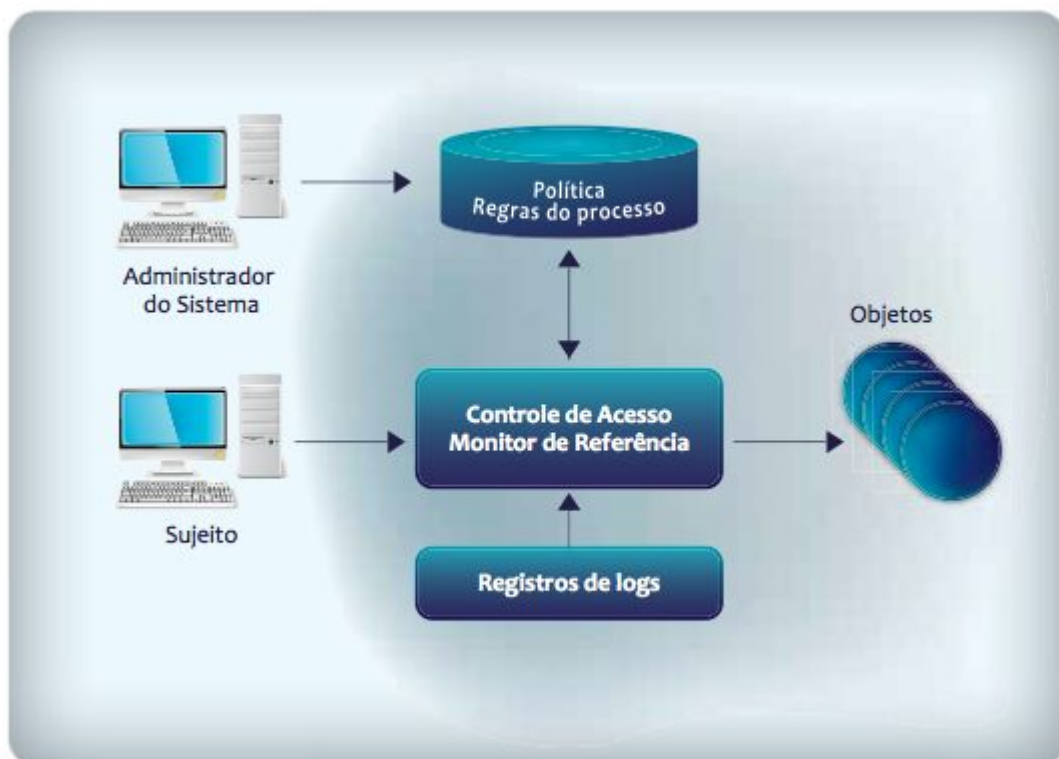


1.1 - Classificação da informação

 **Informações Públicas:** Os dados públicos são aqueles que não precisam de proteção especializada contra vazamentos, já que são de conhecimento público. Todavia, assim como o nível anterior, é importante zelar pela integridade das informações.



1.2 - Controle de acesso à informação



 **Controle de acesso à informação:** o acesso (lógico e físico) deve ser controlado e estar de acordo com as normas e os procedimentos definidos;

1.2 - Controle de acesso à informação

1. Identificação

O sistema identifica quem está tentando acessar a informação.

 *Exemplo:* Um funcionário faz login com seu nome de usuário.

2. Autenticação

Confirma se a identidade é verdadeira.

 *Exemplo:* O sistema exige uma senha, biometria ou autenticação de dois fatores (2FA).

3. Autorização

Define o que a pessoa pode ou não fazer com a informação.

 *Exemplo:*

- Um analista pode **ver** relatórios,
- Mas só o gerente pode **editar** ou **excluir**.

4. Auditoria e Monitoramento

Registra quem acessou o quê, quando e como.

 *Exemplo:* O sistema gera um log de acessos que pode ser analisado para detectar atividades suspeitas.

1.2 - Controle de acesso à informação



Principais tipos de controle de acesso:

Tipo	Descrição
Baseado em função (RBAC)	Acesso é concedido com base no cargo do usuário (ex: RH, TI, Vendas).
Baseado em regras (ABAC)	Usa regras e atributos (ex: horário, localização, dispositivo).
Baseado em listas (ACL)	Lista que diz quem pode acessar um recurso específico.

1.3 - Gerenciar ativos de TI:

 **Inventário e Gerenciamento de Ativos de TIC:** É o processo que identifica, classifica, documenta e monitora todos os ativos críticos de Tecnologia da Informação e Comunicação (TIC) de uma organização.



1.3 - Gerenciar ativos de TI:

Ativos são todos os recursos que armazenam, processam ou transmitem informação, como:

-  Computadores e servidores
-  Dispositivos móveis
-  Sistemas e softwares
-  Bancos de dados
-  Redes e conexões
-  Informações sensíveis e dados de clientes

1.3 - Gerenciar ativos de TI:

Objetivo do gerenciamento de ativos:

- Manter um **registro atualizado** dos ativos
- Garantir a **proteção adequada** de cada ativo
- Ajudar na **gestão de riscos** e conformidade com normas
- Facilitar a **resposta a incidentes** de segurança

1.4 - Gestão de riscos:

 **Gestão de riscos de segurança da informação:** objetiva minimizar os riscos associados à informação, apresentando as medidas de segurança necessárias e realizando a avaliação contínua por meio de análise sistemática e periódica;

Exemplo de Matriz de Riscos (ISO 27005)

Nível de risco	Avaliação de riscos	Descrição
Baixo	Aceitável como é apresentado	O risco pode ser aceito sem mais ações.
Moderado	Tolerável sob controle	Convém que um acompanhamento em termos de gestão de riscos seja realizado, e que ações sejam criadas no quadro de melhoria contínua a médio e longo prazo.
Alto	Inaceitável	Convém que medidas para reduzir o risco sejam tomadas absolutamente no curto prazo. Caso contrário, convém que toda ou parte da atividade seja recusada.

1.4 - Gestão de riscos:



Como funciona o processo de gestão de riscos:

1. Identificação dos riscos

→ Levantamento de ameaças e vulnerabilidades nos ativos

2. Análise e avaliação

→ Determinar a probabilidade e o impacto dos riscos

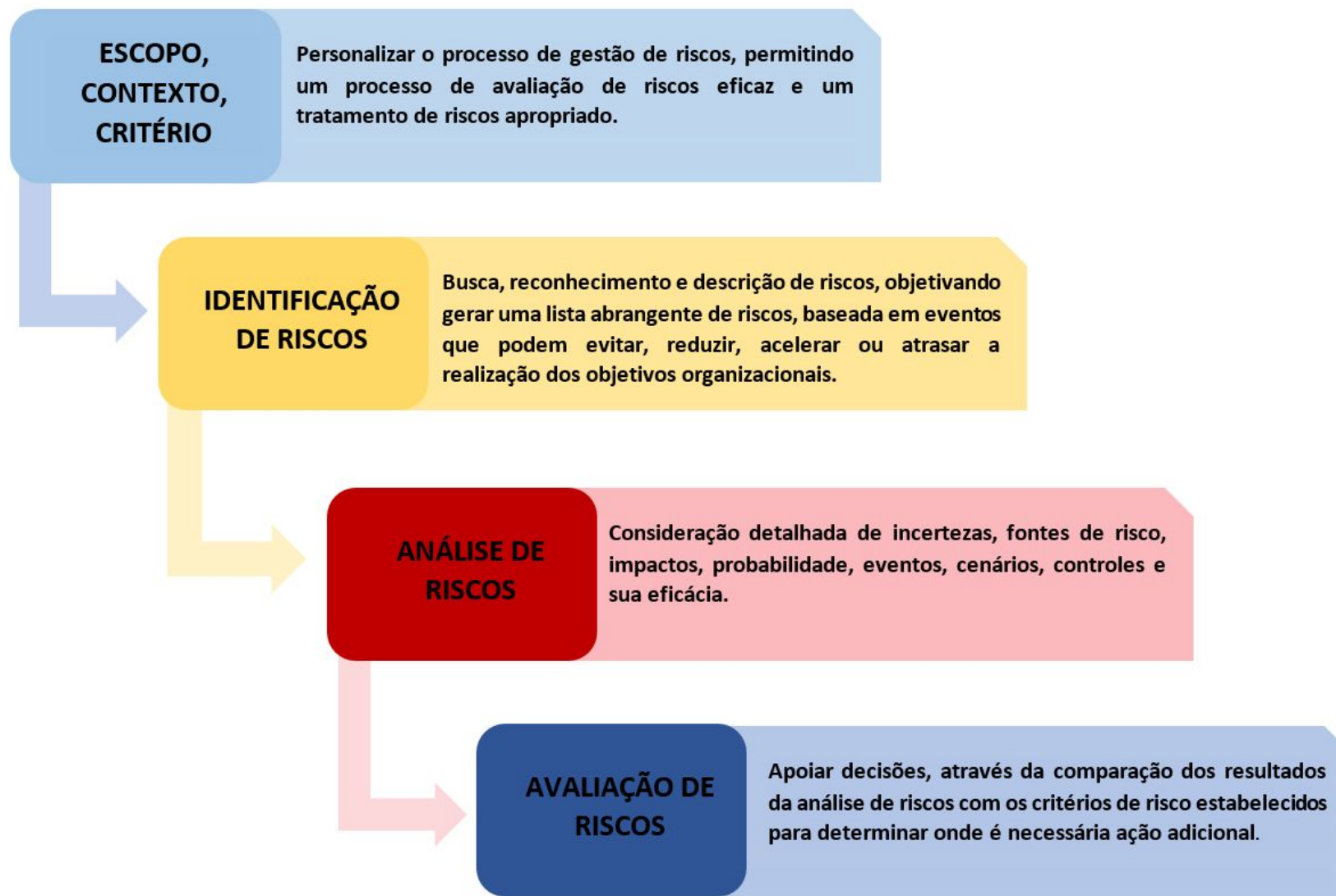
3. Tratamento dos riscos

→ Aplicar controles: evitar, reduzir, transferir ou aceitar

4. Monitoramento contínuo

→ Acompanhamento regular com revisões periódicas

1.4 - Gestão de riscos:



1.5 - Tratamento de incidentes:

 **Tratamento de incidentes em segurança da informação:** visa à continuidade do negócio, tentando reduzir a um nível aceitável a interrupção causada por desastres ou falhas, principalmente, nos ativos que suportam os processos críticos de informação do órgão;



1.5 - Tratamento de incidentes:

Exemplos de incidentes:

- Ataques cibernéticos (ex: ransomware, DDoS)
- Vazamento de dados sensíveis
- Falha de energia ou de servidores
- Erros humanos (ex: envio de dados errados)
- Acesso não autorizado a sistemas

Etapas da resposta a incidentes:

1. **Identificação** – detectar o incidente
2. **Notificação** – comunicar as partes envolvidas
3. **Contenção** – limitar o impacto
4. **Erradicação** – eliminar a causa
5. **Recuperação** – restaurar sistemas afetados
6. **Lições aprendidas** – documentar e melhorar o processo

1.6 - Conscientização e treinamento:

🎓 **Conscientização e treinamento em segurança da informação:** promove a validação das diretrizes da PSI e a definição de utilização e responsabilidade com o uso das informações;





02 - Princípios da segurança da informação

2 - Princípios da segurança da informação



São a base para proteger os dados e sistemas de uma organização. Eles formam o que chamamos de tríade da segurança da informação, com outros princípios complementares que reforçam essa base.

2.1 - Confidencialidade:

✓ **Confidencialidade** nada mais é do que a garantia de que essas informações trafeguem de forma sigilosa e confidencial, e que somente as pessoas autorizadas a essa informação tenham acesso a ela. Este pilar compreende também as restrições de quem pode ter acesso a determinado dado. Quanto mais limitado o acesso, mais segura a informação está.

Confidencialidade

Garantir que as informações sejam acessíveis apenas para pessoas autorizadas.

2.2 - Integridade

 **Integridade** determina que a informação chegue até o destino de forma íntegra. Ou seja, que não tenha sofrido nenhum tipo de modificação não autorizada. Sendo assim a informação chegara ao destinatário tal como ela foi enviada. Esse pilar garante a veracidade da informação.

Integridade

Assegurar que os dados permaneçam íntegros, precisos e não sejam alterados de forma não autorizada.

2.3 - Disponibilidade

 **Disponibilidade** visa garantir que as informações estejam disponíveis para o usuário, a qualquer momento que ele precisar dela. Para este pilar, é necessário um grande investimento em infraestrutura, como *backups* por exemplo, a fim de reduzir as chances de o sistema de armazenamento ficar fora do ar.

Disponibilidade

Atestar que os dados estejam disponíveis quando necessário, sem interrupções não planejadas.

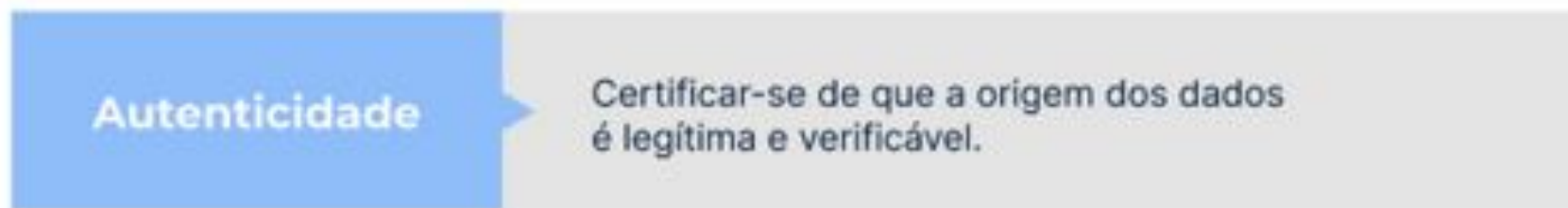
2.4 - Novos pilares da segurança da informação

Atualmente contamos com mais 2 pilares: a **Autenticidade** e a **Conformidade**.



2.4 - Novos pilares da segurança da informação

ID **Autenticidade**, que visa garantir a origem da informação, ou seja, que essa informação seja proveniente de uma fonte confiável. Em outras palavras, é a Autenticidade que assegura que cada dado pertence a quem diz pertencer.



2.4 - Novos pilares da segurança da informação

 **Conformidade**, cujo objetivo é garantir que todo processo obedeça às normas e leis vigentes e devidamente regulamentadas.

Conformidade

Aderir a normas, regulamentos e requisitos legais relacionados à segurança da informação.

2.4 - Novos pilares da segurança da informação

É válido citar também que muitos profissionais da área de Segurança da Informação consideram como um sexto pilar a Irretratabilidade, ou o Não-Repúdio. Este pilar impede que algum usuário negue a autoria de determinada informação.

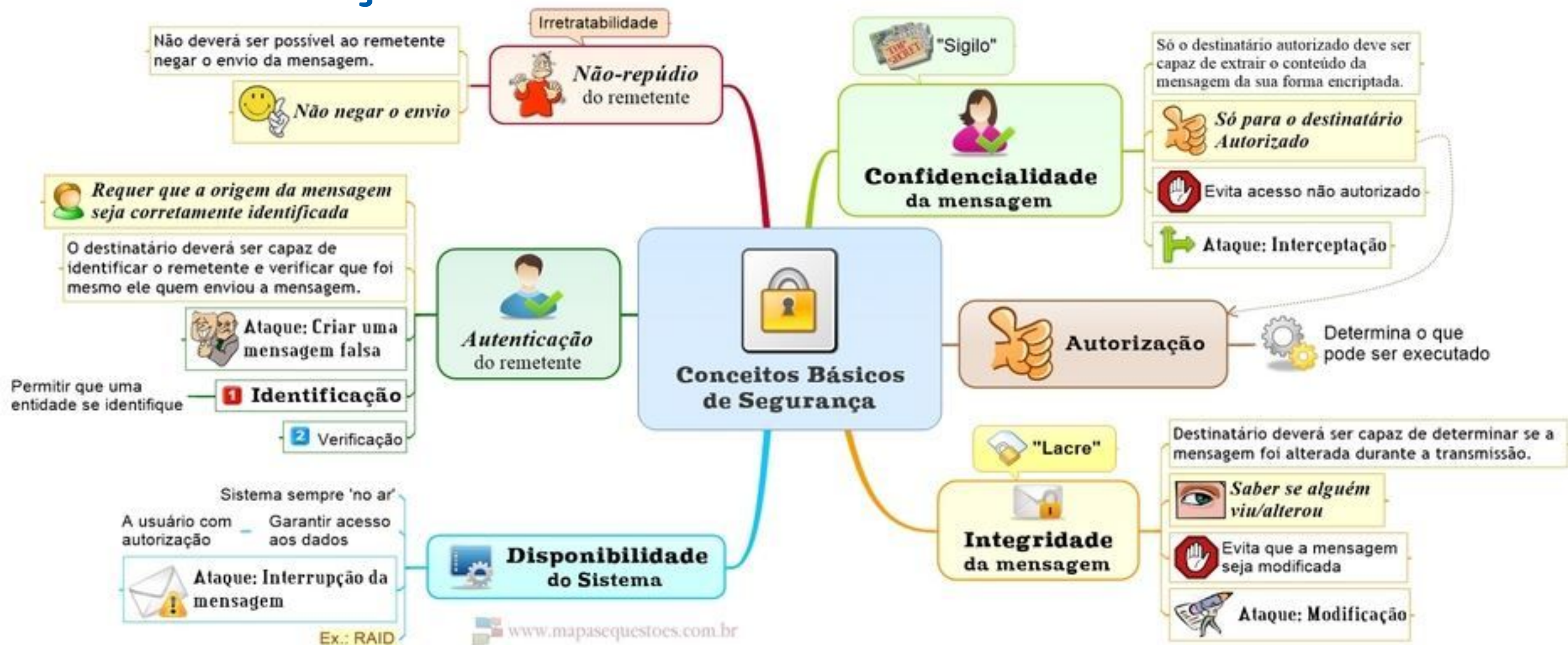


Responsabilidade (ou Não Repúdio): Assegurar que as ações de um usuário possam ser atribuídas e comprovadas, evitando negação de autoria.

Irretratabilidade
(não repúdio)

Evitar que uma parte possa negar a autoria ou envolvimento em uma transação.

2.5 - Mapa Mental Segurança da informação



UniSENAI

Rua São Paulo, 1147 - Victor Konder, Blumenau - SC

 3210 4567

unisenaisc.com.br



SENAI